

SIMATS ENGINEERING
ASSESSMENT TOOL 1 – INDUSTRY PROBLEM TASK

Course:	Code:	CO: CO5	21100
Duration:	Total Marks: 100	Reg No / Name: Udhayakumar (192424332)	

COURSE OUTCOME COVERED

***CO5:** Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Instructions: Answer all questions. Each question carries 20 marks.

1. A mid-sized financial organization operates a Windows domain network consisting of 150 interconnected systems. During a security incident investigation, it is observed that attackers have exploited NULL sessions, open RPC services, and misconfigured shared folders to gain unauthorized access. Initial analysis indicates that 45% of systems allow anonymous enumeration, and among those, 60% are susceptible to SMB-based lateral movement attacks. Furthermore, each compromised system can attempt to access 3 additional systems, with a success probability of 0.3 per attempt.

Question:

Analyze the extent of the attack by calculating the number of systems compromised during the initial stage of exploitation. Further, estimate the spread of the attack in the second stage due to lateral movement. Based on your analysis, evaluate whether the network is at risk of a large-scale compromise (greater than 70% of total systems), and justify which vulnerability (NULL sessions, RPC exposure, or weak shares) should be prioritized for immediate mitigation.

2. An enterprise network consists of 120 systems, out of which 70 systems expose RPC services to the internal network. A vulnerability scan reveals that 40% of these systems are susceptible to known exploits, and the probability of successful exploitation for each vulnerable system is 0.5. However, each exploitation attempt carries a detection probability of 0.25 due to intrusion detection systems deployed within the network.

Question:

Determine the expected number of systems that can be successfully compromised by an attacker. Additionally, compute the expected number of detection alerts generated during the exploitation process. Based on your results, critically evaluate whether an attacker aiming to remain stealthy would proceed with exploitation or adopt alternative attack strategies, providing justification for your reasoning.

3. A cloud-hosted Linux server is running multiple services exposed to the internet. Security analysis identifies four critical services, with independent probabilities of vulnerability being 0.3, 0.2, 0.25, and 0.15, respectively. It is also observed that the system has weak file permissions, which can be exploited with a probability of 0.5 once initial access is gained.

Question:

Evaluate the probability that at least one service is vulnerable and can be exploited by an attacker. Further, compute the overall probability of a full system compromise, considering both service exploitation and privilege escalation through weak permissions. Based on your findings, analyze whether strengthening file permissions alone would significantly reduce the overall risk, and justify your conclusion.

4. An organization uses Network File System (NFS) to share resources across three internal subnets. Due to improper configuration, unauthorized access probabilities from these subnets are estimated as 0.4, 0.3, and 0.2, respectively. Once access to the NFS share is obtained, the probability of privilege escalation to root access is 0.7.

Question:

Calculate the probability that at least one subnet successfully gains unauthorized access to the NFS share. Subsequently, determine the overall probability of a complete system compromise. Based on your analysis, evaluate the effectiveness of restricting NFS access to a single subnet as a mitigation strategy, and justify your recommendation.

5. An e-commerce platform maintains a database containing 50,000 user records, of which 30% are classified as sensitive. A successful SQL injection attack allows data extraction at a rate of 500 records per second. However, the application firewall detects and blocks the attack after 40 seconds.

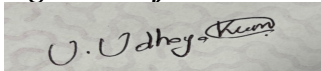
Question:

Compute the total number of records that can be extracted before the attack is blocked. Determine the percentage of total data compromised, and estimate the number of sensitive records exposed. Based on your analysis, evaluate the severity of the breach and justify whether the existing detection mechanism is sufficient to protect critical data.

Code of Conduct:

I UDHAYAKUMAR U (192424332) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

A rectangular box containing a handwritten signature in black ink. The signature appears to be 'U. Udhay Kumar' written in a cursive style.

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning	Mark
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem context	
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts	
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution	
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools	
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis	
Professionalism	5%	Highly professional, well-documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation	

Note on approach: These are quantitative security-risk scenarios rather than tool-based exercises. Each answer follows the same structure — Understanding of the Problem, Application of Engineering Concepts (the probability/expected-value model), the worked Solution, Analysis of the result against the stated threshold, and a Professional recommendation — matching this assignment's rubric. All calculations use standard independence/expected-value assumptions stated explicitly where the problem itself doesn't fully specify the model, since real attack chains have more nuance than a closed-form formula can capture.

Question 1 — Windows Domain: NULL Sessions, RPC, and Lateral Movement

1.1 Understanding of the Problem

150 systems total. 45% permit anonymous (NULL session) enumeration; of those, 60% are further susceptible to SMB-based lateral movement — this combined subset is the initial-stage compromise. From there, each already-compromised system attempts lateral movement against 3 further systems, each attempt succeeding independently with probability 0.3 — this is the second-stage spread.

1.2 Application of Concepts and Solution

Worked calculation

```
Stage 1 (initial compromise):
  Systems allowing NULL-session enumeration = 45% x 150 = 67.5
  Of those, susceptible to SMB lateral movement = 60% x 67.5 = 40.5
  --> Initial-stage compromised systems ~ 40 to 41 systems (expected value 40.5)
Stage 2 (lateral movement spread):
  Each of the 40.5 compromised systems makes 3 attempts at 0.3 success probability
  Expected successful new compromises = 40.5 x 3 x 0.3 = 36.45
  --> ~36 to 37 additional systems compromised (expected value 36.45)
Total compromised after Stage 2:
  40.5 + 36.45 = 76.95 ~ 77 systems
  Percentage of network compromised = 76.95 / 150 = 51.3%
```

1.3 Analysis Against the 70% Threshold

At 51.3%, the network falls **below** the 70% large-scale-compromise threshold after this single round of lateral movement — so under this specific two-stage model, it is not yet at large-scale-compromise risk. This result should not be read as reassuring, however: real lateral movement is rarely limited to one round. If the ~37 newly compromised systems from Stage 2 each also attempt 3 further accesses at the same 0.3 success rate, a third round would add roughly $36.45 \times 0.9 \approx 33$ more systems, pushing the cumulative total past 100 systems — well over the 70% (105-system) threshold. The 51.3% figure therefore represents an early checkpoint in an accelerating chain, not a stable end state.

1.4 Solution Design — Prioritized Mitigation

NULL sessions should be prioritized first. They are the root enabler at the very start of the chain — every downstream number in this analysis (the 40.5 initial compromises and everything that follows) depends on the 45% anonymous-enumeration exposure existing in the first place. Closing NULL-session access (via registry restrictions such as RestrictAnonymous/RestrictNullSessAccess, or modern equivalents) collapses Stage 1 toward zero and therefore prevents Stage 2 from ever having a foothold, regardless of how vulnerable the RPC services or shared folders are individually. RPC hardening and share-permission review should follow as the second and third priorities — meaningful, but structurally downstream of the NULL-session entry point.

1.5 Professionalism — Recommendation

Given the accelerating nature of lateral movement shown above, recommend immediate remediation of NULL-session exposure rather than deferring to a scheduled maintenance window — the marginal cost of a

short, controlled change window is far lower than the cost of a compromise that could plausibly exceed 70% of the domain within two to three propagation rounds.

Question 2 — RPC Exposure, Exploitation, and Detection Trade-off

2.1 Understanding of the Problem

120 systems total, 70 expose RPC. Of those 70, 40% are vulnerable to known exploits. Each vulnerable system has a 0.5 probability of successful exploitation, and each exploitation attempt independently carries a 0.25 probability of triggering an IDS detection alert.

2.2 Application of Concepts and Solution

Worked calculation

```
Vulnerable systems = 40% x 70 = 28
Expected successfully compromised systems = 28 x 0.5 = 14
Expected number of detection alerts = 28 x 0.25 = 7
(assuming one exploitation attempt per vulnerable system, with detection
independent of whether the exploitation attempt itself succeeds)
```

2.3 Analysis — Stealth Trade-off

An attacker attempting all 28 exploits can expect 14 successful compromises, but also an expected 7 IDS alerts along the way. Seven expected alerts out of 28 attempts is a large, difficult-to-hide signal — with detection probability 0.25 per attempt, the probability of triggering zero alerts across all 28 attempts is only $(0.75)^{28} \approx 0.04\%$, meaning an attacker mass-exploiting all 28 systems should expect near-certain detection well before finishing. A genuinely stealth-focused attacker would therefore not proceed with this wholesale approach.

2.4 Solution Design — Alternative Attacker Strategy (for defensive awareness)

A stealthier attacker would instead: target only a small number of the highest-value systems rather than all 28, spread attempts over a longer time window to avoid burst-pattern IDS signatures, use exploitation techniques with lower detection signatures than the default (e.g. tailored payloads instead of common automated-framework signatures), and pause or abort after the first one or two alerts rather than continuing en masse. Recognizing this trade-off helps a defender understand that the absence of many alerts does not imply the absence of compromise — a patient attacker optimizes precisely to stay under this kind of detection budget.

2.5 Professionalism — Recommendation

Recommend patching the 28 vulnerable RPC systems as the primary control (eliminating the exploitation surface directly), while also tuning IDS alert thresholds and correlation rules so that even a small number of low-and-slow exploitation attempts — the pattern a stealthy attacker would actually use — is still reliably flagged, rather than relying on volume alone to trigger detection.

Question 3 — Cloud Linux Server: Combined Service and Privilege-Escalation Risk

3.1 Understanding of the Problem

Four independently vulnerable services with probabilities 0.3, 0.2, 0.25, and 0.15. Weak file permissions allow privilege escalation with probability 0.5 once any initial access is gained. Two quantities are required: the probability at least one service is exploitable, and the overall probability of full system compromise combining both stages.

3.2 Application of Concepts and Solution

Worked calculation

```
P(no service vulnerable) = (1-0.3) (1-0.2) (1-0.25) (1-0.15)
                        = 0.7 x 0.8 x 0.75 x 0.85 = 0.357
P(at least one service vulnerable) = 1 - 0.357 = 0.643 (64.3%)
P(full system compromise)
  = P(at least one service vulnerable) x P(privilege escalation)
  = 0.643 x 0.5 = 0.3215 (32.15%)
```

3.3 Analysis — Is Fixing File Permissions Alone Sufficient?

If weak file permissions were fully remediated (privilege-escalation probability reduced to 0), the *combined* full-compromise probability calculated above would indeed fall to 0% for this specific privilege-escalation path. However, the underlying initial-access exposure — a 64.3% probability that at least one of the four services is independently exploitable — is completely untouched by this fix. An attacker could still gain initial foothold through any of the four vulnerable services and then pursue other privilege-escalation routes (kernel exploits, misconfigured SUID binaries, cron-job weaknesses, etc.) that this scenario doesn't even model. Strengthening file permissions alone therefore addresses only one link in the chain, not the dominant risk driver.

3.4 Solution Design — Recommendation

Patch or reconfigure the four exposed services first, since a 64.3% initial-access probability is the larger and more actionable risk driver; harden file permissions in parallel as a defense-in-depth measure against privilege escalation, but not as a standalone fix. The combination — reducing both the initial-access probability and the escalation probability — is necessary to meaningfully reduce the 32.15% full-compromise figure, since either factor alone leaves a substantial residual risk from the other.

Question 4 — NFS Multi-Subnet Exposure and Root Escalation

4.1 Understanding of the Problem

Three subnets have independent unauthorized-access probabilities of 0.4, 0.3, and 0.2 to a shared NFS resource. Once any subnet gains access, privilege escalation to root succeeds with probability 0.7. The task asks for the combined access probability, the overall compromise probability, and an evaluation of restricting access to a single subnet as mitigation.

4.2 Application of Concepts and Solution

Worked calculation

```
P(no subnet gains access) = (1-0.4) (1-0.3) (1-0.2) = 0.6 x 0.7 x 0.8 = 0.336
P(at least one subnet gains access) = 1 - 0.336 = 0.664 (66.4%)
P(complete system compromise) = P(at least one subnet access) x P(root escalation)
                              = 0.664 x 0.7 = 0.4648 (46.48%)
Mitigation scenario -- restrict NFS to the single lowest-risk subnet (0.2):
P(compromise, single subnet) = 0.2 x 0.7 = 0.14 (14%)
```

4.3 Analysis — Effectiveness of Single-Subnet Restriction

Restricting NFS access to just the best-controlled subnet (0.2 access probability) reduces the overall compromise probability from 46.48% to 14% — a reduction of over 3.3x. This is a highly effective mitigation precisely because the three subnets' risks combine multiplicatively via the "at least one" formula: eliminating two of the three access paths removes their contribution entirely rather than just reducing it proportionally, since the formula's power comes from needing *all* paths to fail simultaneously for the network to be safe.

4.4 Solution Design — Recommendation

Recommend restricting NFS exports to the single subnet with the lowest demonstrated unauthorized-access probability, combined with NFS-level access controls (export restrictions to specific host/IP ranges, Kerberos-based NFS authentication rather than IP-only trust, and root-squash configuration to blunt the specific privilege-escalation path modeled here). Restricting to one subnet alone still leaves a 14% compromise probability, so it should be paired with hardening that subnet's own access controls rather than treated as a complete fix.

Question 5 — SQL Injection Data Exfiltration Rate and Detection Window

5.1 Understanding of the Problem

50,000 total records, 30% classified sensitive. A SQL injection attack extracts records at 500 per second and is detected/blocked after 40 seconds. The task asks for total records extracted, percentage of the database compromised, sensitive records exposed, and an evaluation of whether the detection speed was adequate.

5.2 Application of Concepts and Solution

Worked calculation

```
Total records extracted = 500 records/sec x 40 sec = 20,000 records
Percentage of database compromised = 20,000 / 50,000 = 40%
Sensitive records exposed (assuming uniform distribution of the 30% sensitive
records across the table, so the same proportion applies to whatever was extracted):
= 30% x 20,000 = 6,000 sensitive records
```

5.3 Analysis — Severity and Detection Adequacy

Losing 40% of an entire customer database — including an estimated 6,000 sensitive records — in a single 40-second window is a severe breach by any standard severity scale, regardless of the fact that the attack was eventually blocked. The detection mechanism did function (the attack was stopped rather than running indefinitely), but a 40-second detection-and-response window against a 500 records/sec exfiltration rate is far too slow relative to the attack's throughput: at this rate, even a 5-second detection delay would already leak 2,500 records, and detection needs to operate on a sub-second-to-few-second basis to meaningfully cap exposure for an attack at this speed.

5.4 Solution Design — Recommendation

The existing detection mechanism is **not sufficient** for protecting critical data against high-throughput automated extraction. Recommend: rate-based anomaly detection on database query volume per session/IP with a much shorter alert threshold (seconds, not tens of seconds); WAF rules that block on abnormal response-row-count patterns rather than only known injection signatures; parameterized queries to prevent the injection at its root rather than relying on detection as the primary control; and query-result throttling/pagination limits that cap how many records any single request can return, which would limit exposure even if detection is delayed.

Consolidated Summary

Q	Scenario	Key Result	Priority Recommendation
1	Windows domain NULL/RPC/lateral movement	~77 systems (51.3%) after stage 2; below 70% but accelerating	Fix NULL sessions first (root enabler)
2	RPC exploitation vs. IDS detection	14 expected compromises, 7 expected alerts	Patch RPC; tune IDS for low-and-slow attacks
3	Cloud server multi-service + weak permissions	64.3% initial access; 32.15% full compromise	Patch services first; harden permissions in parallel
4	NFS multi-subnet + root escalation	46.48% full compromise; 14% if restricted to 1 subnet	Restrict to lowest-risk subnet + NFS auth controls
5	SQL injection exfiltration rate	20,000 records (40%); 6,000 sensitive records exposed	Faster detection + parameterized queries + throttling

Note: all figures above are expected values / theoretical probabilities derived directly from the stated inputs using standard independence assumptions; real-world figures would vary with actual attacker behavior, network topology, and detection-system tuning.